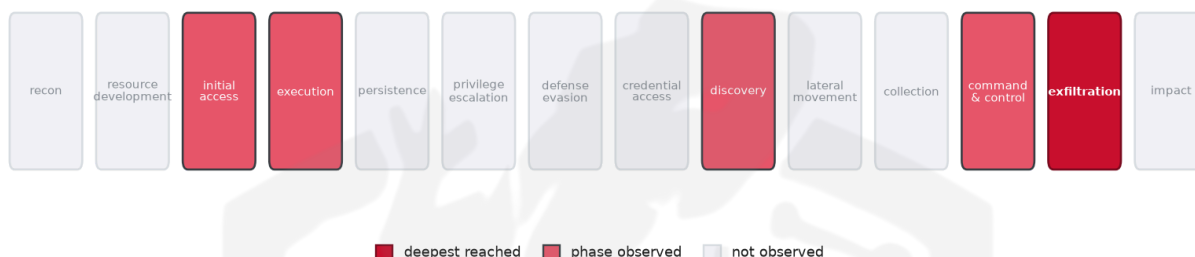


THREAT REPORT: APT28 TARGETS DEFENSE AND DIPLOMACY WITH HOOKEDGE

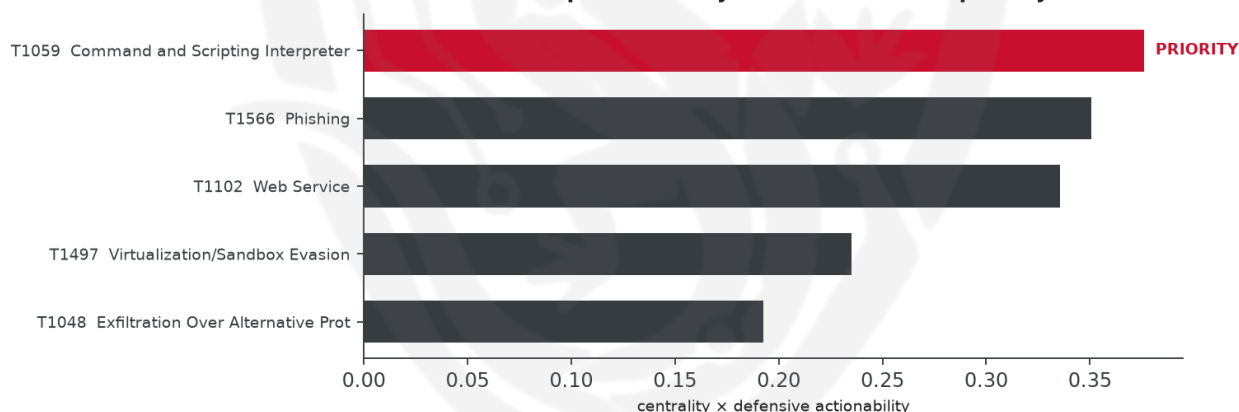
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The source attributes this activity to APT28, which has deployed the HOOKEDGE and HEADLACE malware families against government and defense entities in Romania and Spain. No specific CVE was identified in the report. The campaign leverages a range of techniques, including phishing and web-service based command and control. Priority should be given to constraining PowerShell for unprivileged users (Constrained Language Mode + AppLocker), enabling script-block logging, and blocking wscript/cscript where they are not required.

Threat Overview

APT28 is observed operating the HOOKEDGE and HEADLACE malware families. The report does not cite a concrete vulnerability, noting the central CVE as “Data Insufficient.” The adversary’s focus is on

governmental and defense sectors within Romania and Spain.

Attack Chain and Priority Control

The reporting indicates a chain that begins with phishing (T1566) to gain initial access, followed by the use of web services (T1102) for command and control, exfiltration over alternative protocols (T1048), and virtualization/sandbox evasion (T1497). The priority technique identified is **T1059 – Command and Scripting Interpreter**. The concrete control recommended is: **Constrain PowerShell for unprivileged users (Constrained Language Mode + AppLocker); enable script-block logging; block wscript/cscript where unneeded.**

Infrastructure and Corroboration

The enrichment data did not identify any hosting providers or ASNs associated with the malicious infrastructure (n/a). No indicators were flagged with high confidence on AbuseIPDB, and abuse.ch did not corroborate any malware families.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, machine-extracted from report text — reduced confidence)

The source pulse carried no expert ATT&CK tags, so these techniques were inferred from its narrative by a self-consensus LLM extractor and validated against the ATT&CK catalogue. Treat this technique set, and the chokepoint, kill-chain and risk scores derived from it, as lower-confidence than an expert-tagged brief. - T1048 Exfiltration Over Alternative Protocol - T1059 Command and Scripting Interpreter - T1102 Web Service - T1497 Virtualization/Sandbox Evasion - T1566 Phishing

Analytical Scores

- Priority technique (graph chokepoint): T1059 Command and Scripting Interpreter (centrality 0.47).
- Operational risk: Critical (score 0.822, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3162; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
TA459	0.3162
Thrip	0.3162
AppleJeus	0.3162
Evilnum	0.3078
APT12	0.2981

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Hash	58cfb8b9fee1caa94813c259901dc1baa96bae7d30d79b79a7d441d0ee4e577e
Hash	9097d9cf5e6659e869bf2edf766741b687e3d8570036d853c0ca59ae72f9e9fc
Hash	b0f9f0a34ccab1337fbcca24b4f894de8d6d3a6f5db2e0463e2320215e4262e4
Hash	df60fa6008b1a0b79c394b42d3ada6bab18b798f3c2ca1530a3e0cb4fbbbe9f6
Hash	ed8f20bbab18b39a67e4db9a03090e5af8dc8ec24fe1ddf3521b3f340a8318c1
Hash	7c103519b975225c26b3c73e56295dde
Hash	8473a9fb11f822ef738259d4528f9d25
Hash	b46cbc0a5405703f110218d4ee2e46eb
Hash	c9f3e6057e1809c10514f6a923a15860
Hash	eba56e503290204ab2bd77b130b3a1e4
Hash	2774b165fab2d2f61a709f4d0411a87fcde920d2
Hash	2dc99ef518c3c7fa62f26cd1cc6da9acb376b037
Hash	5da5bd587b6039940586a98088f868c31c0b7129
Hash	de037b7e5e93ba1f8f6933d479f1216a9f01ecb2

Type	Indicator
Hash	e4b61165be5937987b88352d2f1f8d57def30408
Hash	001b57368c10bee9e62374e3b3f232b113eb75a1f198243d43a5bb90e1d0f500
Hash	206bd177f3f3b637b0a444ce2dd6d5aaaefc9d66c866ac6ec0c9e946ce140991
Hash	231164362b2e4688e5d64ef7154845d655b649470bf995a79107b800ac5663b1
Hash	2793e7caba2f9beecd9b01baf41b8cb79f5a1a083ddedc6602ff23996bdc3104
Hash	2e320c457658d35a2bb7c420c53bdcc3916f01a7dd4572e5540e8fce923d201b
Hash	2e81945ba27108cc613a8aa6aca409ad6f5204e647d08dd9ef7c881c9d28667a
Hash	38f0e1e00d5c6d4afd96217556ba1dbe963298be4f9f0890fc1a7618bed009bd
Hash	5f2a06bb1d1a210e9c477e4e5db439ce7b11fe9345d39b1b959905ba576a076a
Hash	74456a8d6042a4232071bee99e25d23046b993486d6d8a98ab296915bbb53395
Hash	7d8e98c0e322110021ae6d89f1a3ea090ef0741cf35b040dd4d0426a502d4845
Hash	877648c6ff448aa4efe1e3f004c089411285b8cb4139320e0dbec9d1d1bb3c77
Hash	87c15e4cf30098dcbfe9fd506c42896bf6d856aa77a70f312dd621b443b61dc3
Hash	8f18e02cbe1fa7abd280d2e070efe7af07e20cfe635f81140d6d347c292f8f44
Hash	9c02d5429717001c55420730ee345c172e7ed89df3052b1e32b9bd122fce616d
Hash	aebf896b2f60c52af5d38c036159e0243632134643e8ad374cb64ed8cb09f360
Hash	b1d037e9ff070d9722b7b289629d9b64a08ec35fd843cc01d37e6db69781ddcb
Hash	b8a1494b68617de92a3f58af8ca49dda4e9894f24c718ff3b26897a340e45c80
Hash	bfc008f57dca8c6bf341d9d7cf66cdad53faf8b1bcfbbeded4593a60f129174b6
Hash	c2c9187033d22d7944ea9298461a0ac693ef2774b4ce08b0955d2aba3646fb44
Hash	c6db004f2e8ff321d8a0e6d0134f2737d0f6ff79a4627a4b803ef926c107aa00
Hash	f611e5415e21f229f75a42011d092e781ffe4118bb70ac95b9d85c41c81ef6ca

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1059 Command and Scripting Interpreter (execution)
- **Observed here:** T1059 Command and Scripting Interpreter was the execution control point here; the pivot is drawn from APT28's own documented ATT&CK repertoire.
- **Projected pivot:** T1204 User Execution (execution)
- **Basis:** documented in APT28's own ATT&CK repertoire, and disproportionately paired with Command and Scripting Interpreter across tracked groups (lift 1.1, ~1.1x base rate). Their move, not a generic one.

With T1059 Command and Scripting Interpreter blocked, APT28 could preserve the same objective by pivoting to T1204 User Execution, a technique from APT28's documented repertoire. Defensive countermeasure: Block execution of downloaded HTA/JS/LNK; enforce mark-of-the-web; disable Office macros from the internet; user awareness on lures.

Also plausible (same tactic): T1203 Exploitation for Client Execution (n=32, lift 1.1), T1559 Inter-Process Communication (n=13, lift 1.3)

Detection and hardening for the pivot (T1204 User Execution)

- **Telemetry:** Endpoint process telemetry; Email/proxy logs
- **Detect:**
 - User double-clicking archive/ISO/LNK contents that spawn interpreters
 - Mark-of-the-Web on delivered files; LOLBIN execution from user temp paths
- **Harden:**
 - Block risky file types; ASR rules; user awareness training
 - Application control to stop execution from user-writable directories
- **MITRE:** M1049 Antivirus/Antimalware, M1038 Execution Prevention, M1017 User Training · DS0009 Process, DS0022 File